ThinkHub

THINK · LEARN · GROW

How Do Hackers Actually Hack Accounts?

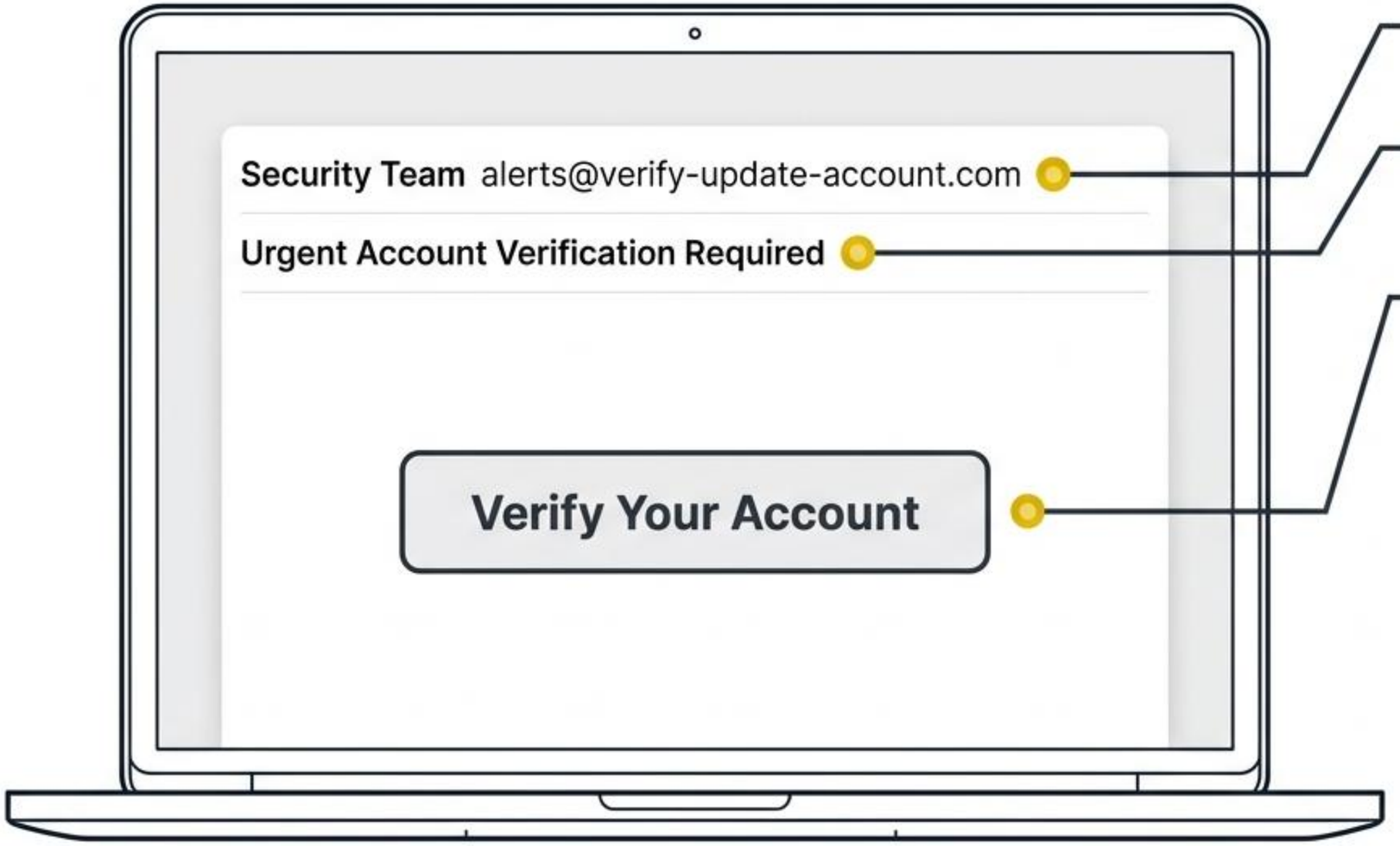
The Hidden Science of Cybersecurity





Daksh Khandelwal
Founder, ThinkHub

The Message That Can Compromise Your Account



1. **Fake Sender Domain**
2. **Creates Artificial Urgency / Fear**
3. **Directs to a Lookalike Phishing Page**

Sometimes, hackers don't need to break into your computer. They only need you to trust the wrong message.

Cybersecurity begins before a password is ever typed.

Gemini Notebook

What Actually Happens When an Account Gets Hacked?



Account Takeover (ATO)

Unauthorized access gained by an attacker, leading to fraud, impersonation, or data theft.

The Master Key

Many online services rely entirely on email for password resets and verification.

The Misconception

Hackers rarely use sophisticated programming to bypass core systems; they exploit interconnected credentials, vulnerable devices, or active sessions.

Gemini Notebook

The Five Major Ways Attackers Gain Access

1. Phishing
Tricking users into revealing sensitive information through impersonation (Email, SMS, Voice).

2. Password Reuse
Exploiting the habit of using the same password across multiple independent services.

3. Credential Stuffing
Automated bots testing previously stolen username/password combinations across new websites.



4. Social Engineering
Exploiting human psychology (fear, urgency, curiosity) rather than technical flaws.

5. Session Theft
Stealing active authentication tokens to bypass the password-entry process entirely.

There is no single method to hack an account. Attackers choose the path of least resistance based on the target's specific weaknesses.

Gemini Notebook

Phishing: Hacking Through Human Trust

Genuine Web Environment



Domain:	Official corporate domain
Destination:	Trusted, verifiable server
Outcome:	Secure official authentication

Lookalike Impersonation

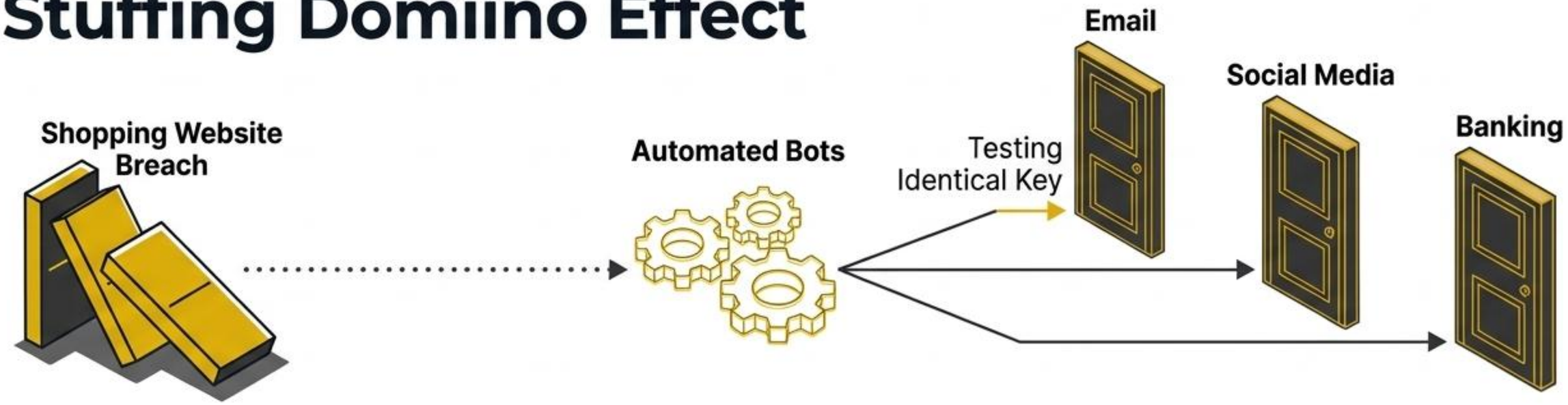


Domain:	Lookalike domain
Destination:	Attacker-controlled database capturing keystrokes
Outcome:	Stolen credentials

The HTTPS Padlock Myth: HTTPS and the padlock symbol only indicate an encrypted connection. They do NOT prove a website is trustworthy. Bad actors can encrypt fake sites, too.

Gemini Notebook

Password Reuse and the Credential Stuffing Domiino Effect

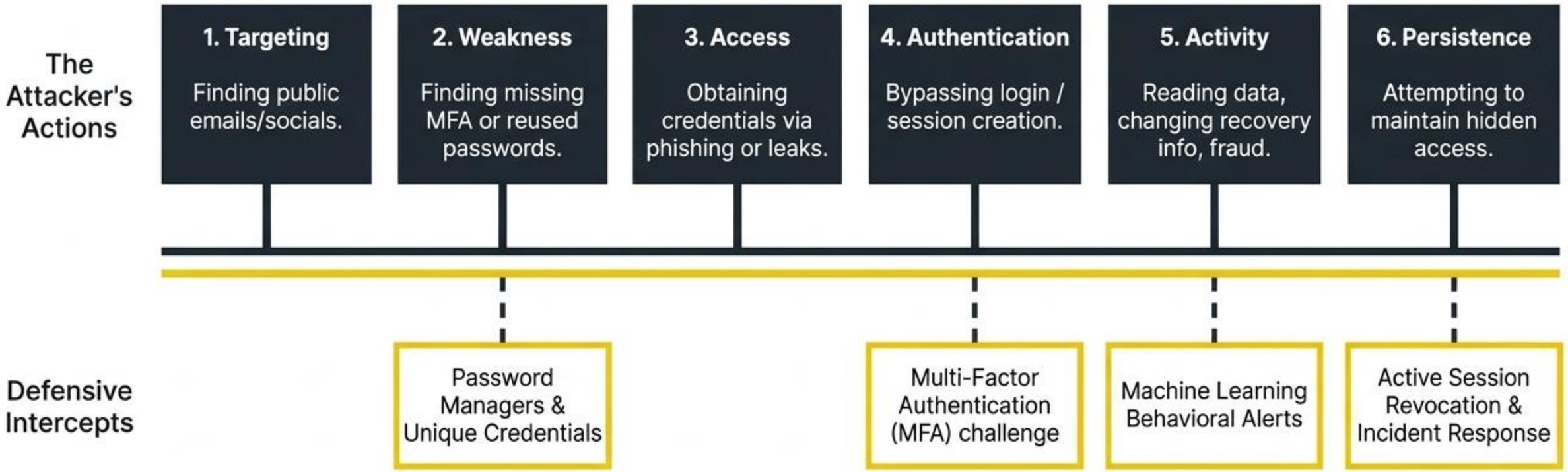


1. Breach	2. Acquisition	3. Automation	4. Compromise
User credentials are exposed in a low-security website breach.	Attackers obtain the leaked database lists.	Bots test the exact username/password combinations against high-value services.	Reused passwords unlock multiple accounts instantly.

Key Distinction: Credential stuffing is not brute-force guessing; it relies on already-known, leaked combinations. A single unique password breaks this entire chain.

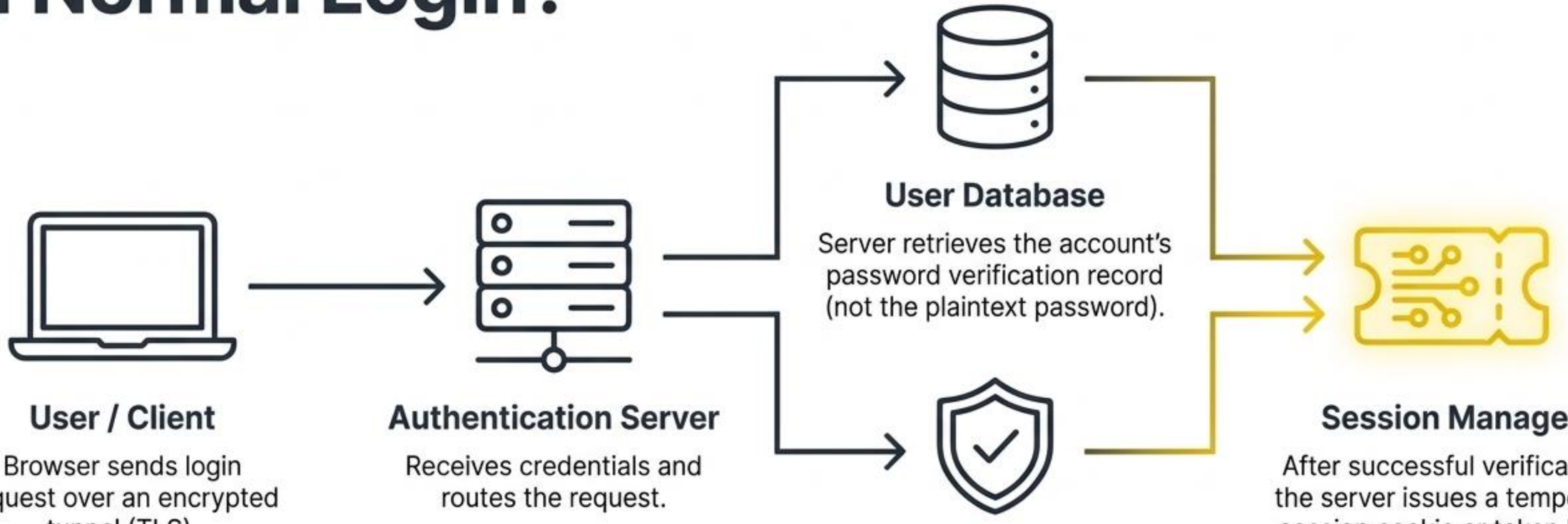
Gemini Notebook

Inside an Account Compromise: The Six-Step Journey



Gemini Notebook

What Happens During a Normal Login?



User / Client

Browser sends login request over an encrypted tunnel (TLS).

Authentication Server

Receives credentials and routes the request.

User Database

Server retrieves the account's password verification record (not the plaintext password).

MFA Provider

Generates an additional identity verification challenge if required.

Session Manager

After successful verification, the server issues a temporary session cookie or token back to the browser.

Security Note: Security monitoring continuously evaluates activity throughout this entire pipeline to catch anomalies.

Gemini Notebook

Passwords, Hashing, and Encryption: The Architecture of Secrecy



Plaintext

Readable original information.

Highly dangerous if stored this way on a server.



Encryption

Converts plaintext into unreadable ciphertext.

Reversible with the correct key.

Protects data in transit (TLS) and at rest.



Hashing

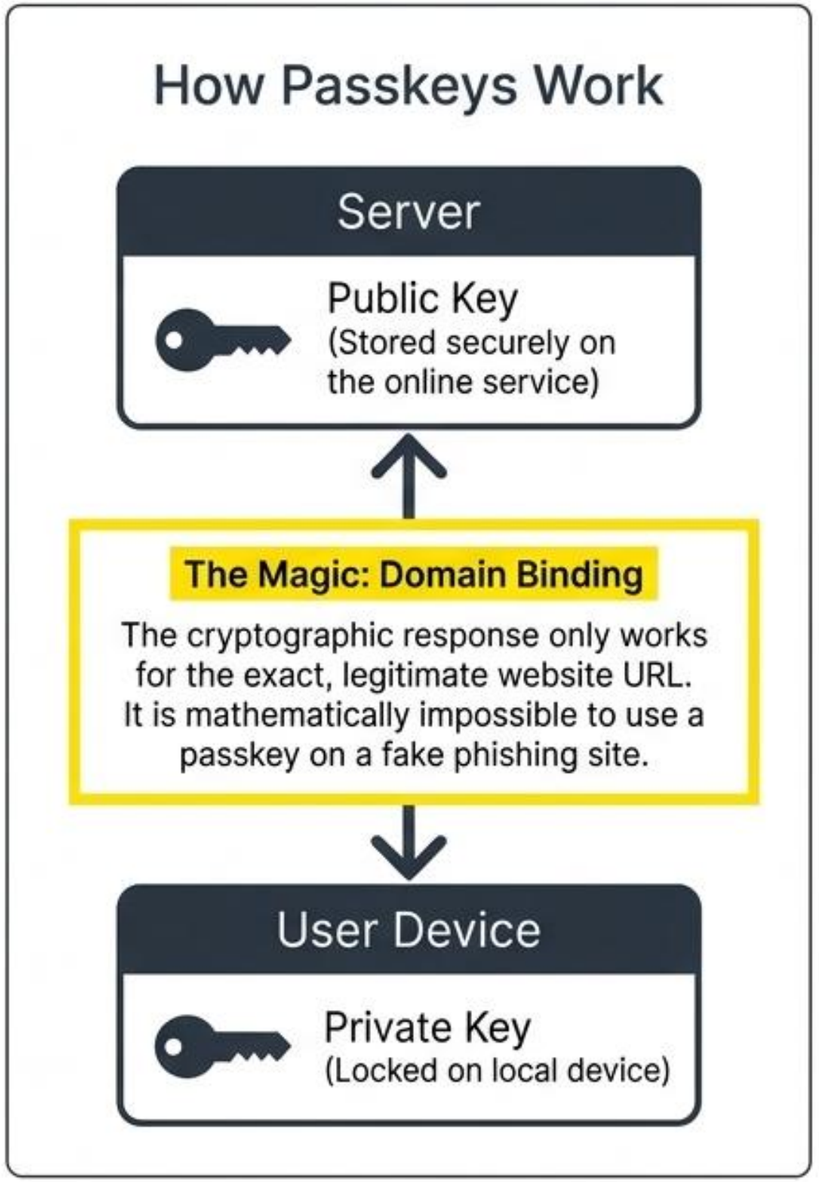
A one-way cryptographic transformation. Cannot be reversed into the original password.

Uses unique random salts and algorithms (e.g., Argon2id, scrypt) to securely verify passwords without storing them.

Gemini Notebook

MFA and Passkeys: The Future of Authentication

Evolution Matrix	
Password Only	One secret factor. High theft/phishing risk.
Password + MFA	Multiple factors (Knowledge + Possession/Biometric). Stronger protection, but manual OTPs/SMS can still be intercepted or relayed.
Passkeys (FIDO2/WebAuthn)	Public-key cryptography. Replaces the password entirely. Inherently phishing-resistant.



Gemini Notebook

The Hidden Risk: Session Hijacking



1. Verification

User trades their ID (Password/MFA) at the front desk (Server).



2. Issuance

The front desk issues a temporary Keycard (Session Token / Cookie).



3. Access

The user can now navigate the hotel without showing their ID at every door.

The Hijack

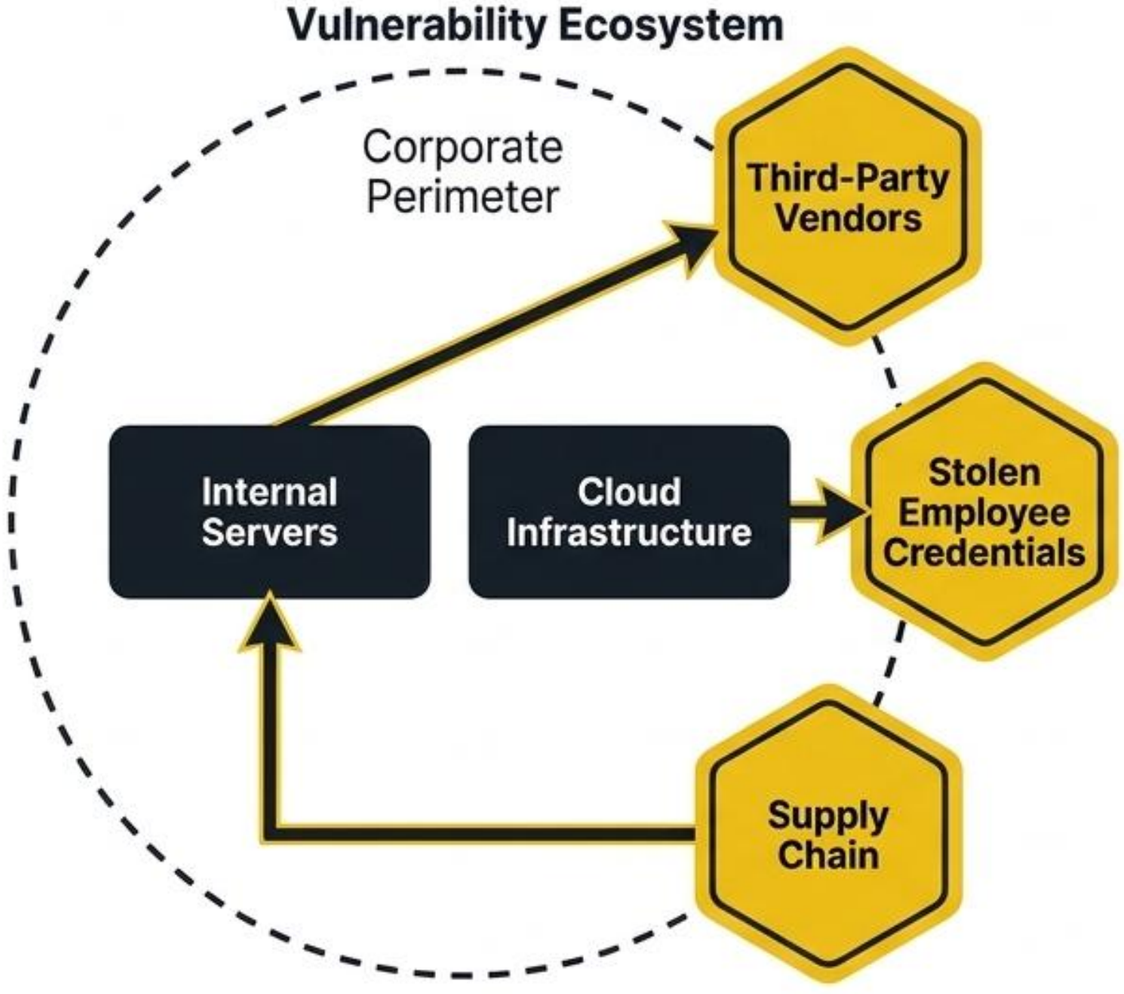
If a device is infected with malware, an attacker can steal the active Keycard (Session Token).

The Consequence

The attacker bypasses the password and MFA entirely. Changing a password does not automatically invalidate a stolen session—users must actively use “Sign Out Everywhere” features.

Gemini Notebook

Why Even the Biggest Companies Get Hacked



The Myth: Large organizations are impenetrable digital fortresses.

The Reality: They are complex, interconnected supply chains relying on humans and external vendors.

30% Breaches involving third-party vendor compromise.

34% Increase in the exploitation of software vulnerabilities.

22% Initial access gained through credential abuse.

(Verizon 2025 DBIR Data)

Conclusion: Even if a company's internal servers are secure, they remain vulnerable to supply chain attacks, misconfigured cloud buckets, and stolen employee credentials.

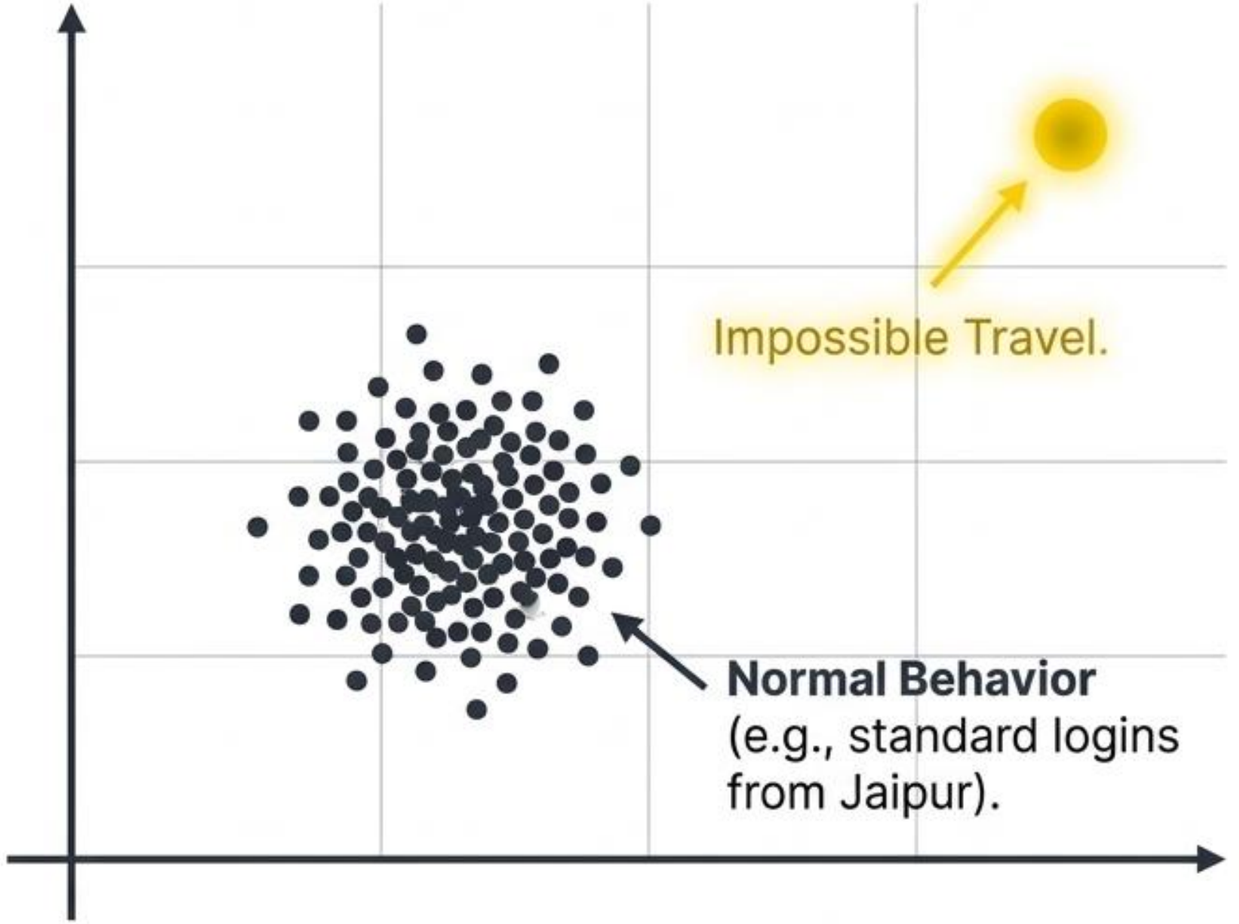
Gemini Notebook

How Machine Learning Detects Suspicious Logins

Raw Signals: Device Type, Browser, Location, Time, Velocity

Feature Extraction: Converts activity into analyzable data

Anomaly Engine: Compares real-time data against established baselines



The Security Response: ML generates a risk score. High scores trigger immediate session restrictions or demand step-up MFA verification, recognizing that the password was correct, but the behavior is fraudulent.

Gemini Notebook

The New Cybersecurity Landscape: 2025–2026



NIST SP 800-63-4 Guidelines

US National Institute of Standards and Technology releases updated digital identity guidelines, heavily prioritizing phishing-resistant authentication and synchronized authenticators (Passkeys).

The Rise of Passkeys

Accelerated global adoption of FIDO2 standard passwordless logins to combat credential stuffing.

CERT-In Advisory (CIAD-2026-0037)

India's Computer Emergency Response Team issues a critical warning regarding Microsoft 365 environments.

The Shift

The CERT-In advisory explicitly highlights that attackers are **moving beyond basic passwords**—targeting sessions via device-code phishing, password spraying, and MFA-bypass techniques. The frontline is **now identity and session security**.

Gemini Notebook

The Actionable Defense Checklist

Phase 1: Secure Core Accounts



- Lock down your primary email first—it is the master key to everything else.
- Never reuse passwords. Use a reputable password manager.
- Enable MFA (preferably phishing-resistant Passkeys) everywhere supported.

Phase 2: Protect Devices & Sessions



- Keep operating systems and browsers aggressively updated.
- Avoid logging into sensitive accounts on untrusted shared devices.
- Regularly review active sessions and revoke permissions for unfamiliar third-party apps.

Phase 3: Incident Response (If Compromised)



- Recover access via official websites only. Change credentials from a trusted device.
- Force '**Sign Out Everywhere**' to kill stolen session tokens.
- **India Specific Resource**: Report financial cybercrimes immediately to the National Cyber Crime Reporting Portal or call helpline 1930.

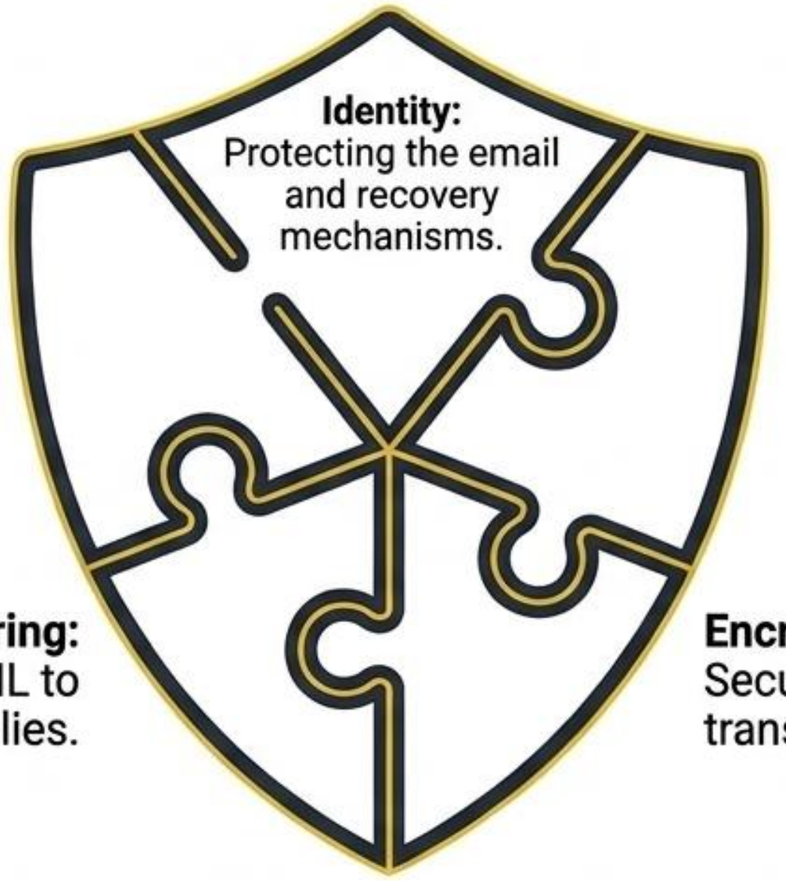
Gemini Notebook

Cybersecurity Is A Shared Responsibility

Identity:
Protecting the email and recovery mechanisms.

Awareness:
Building human resilience against social engineering.

Authentication:
Enforcing MFA and Passkeys.



Monitoring:
Deploying ML to catch anomalies.

Encryption:
Securing data in transit and at rest.

Closing Insight: The strongest cybersecurity strategy is not simply building higher walls. It is reducing opportunities for compromise, detecting anomalous behavior, and limiting the blast radius when something goes wrong.

Think Before You Click. Verify Before You Trust. Secure Before It's Too Late.

Gemini Notebook

ThinkHub

THINK. LEARN. GROW.

THANK YOU!

The future belongs to those who build it continuously.

START TODAY.
Take the first step.

STAY CONSISTENT.
Small steps, big results.

BUILD ONE PROJECT
at a time.



PRESENTED BY

DAKSH KHANDELWAL

FOUNDER, THINKHUB

CONNECT WITH ME

Scan to connect on LinkedIn

LIKE | SUBSCRIBE | COMMENT

KEEP LEARNING. KEEP BUILDING. KEEP GROWING.